

UNIVERSIDAD PRIVADA FRANZ TAMAYO
FACULTAD DE INGENIERÍA
INGENIERÍA DE SISTEMAS



Fetal Medical Bolivia:
Diseño Completo de Sistema de Historia Clínica Gineco-Obstétrica con
Inteligencia Artificial

Integrante: Miguel Mirkof Becerra Guzmán

Gestión I – 2026
La Paz – Bolivia

Resumen

El presente documento expone el diseño arquitectónico completo del sistema Fetal Medical Bolivia, una plataforma web de historia clínica gineco-obstétrica con módulo de inteligencia artificial para el análisis de ecografías mediante redes neuronales convolucionales (CNN). El sistema opera bajo arquitectura de microservicios, empleando Django REST Framework, FastAPI, React 18 con TypeScript, PostgreSQL 16 y PyTorch 2 con la biblioteca MONAI para el procesamiento de imágenes médicas DICOM. El documento cubre dominio clínico, arquitectura de software, metodología de desarrollo, stack tecnológico, modelo de datos, pipeline de IA/ML, seguridad, privacidad y plan de construcción, fundamentado en fuentes académicas estándar de la ingeniería de software y la inteligencia artificial médica.

1. Dominio y Contexto

1.1 Conocimiento del Dominio para el Ingeniero de Software

La ginecología y obstetricia es la especialidad médica que abarca la salud del aparato reproductor femenino y la gestión integral del embarazo, parto y puerperio. Cualquier sistema de información en este dominio opera bajo riesgo vital directo: los errores diagnósticos pueden derivar en pérdida fetal, muerte materna o daño permanente. Sommerville (2016) clasifica estos sistemas como safety-critical software, para los cuales exige un nivel de rigor metodológico y de verificación significativamente superior al software comercial estándar.

En Bolivia, el ejercicio médico está regulado por la Ley 3131 (Ley del Ejercicio Profesional Médico, 2005). Todo sistema de apoyo diagnóstico tiene implicaciones legales directas bajo esta norma. El módulo de inteligencia artificial del presente sistema es soporte diagnóstico, no sustituto del juicio clínico: el médico es siempre el responsable del diagnóstico final.

1.2 Terminología Clínica Estándar

Tabla 1

Terminología gineco-obstétrica aplicable al sistema

Término	Definición clínica
Historia Clínica Gineco-Obstétrica	Registro cronológico completo de los eventos de salud reproductiva de una paciente, con valor legal según RM 1328 de Bolivia
DICOM	Digital Imaging and Communications in Medicine. Estándar ISO 12052 para imágenes médicas
Ecografía obstétrica	Estudio ultrasonográfico de evaluación fetal, placentaria y de líquido amniótico
Biometría fetal	Mediciones ecográficas: BPD (diámetro biparietal), HC (circunferencia cefálica), AC (abdominal), FL (fémur)

Término	Definición clínica
Edad gestacional (EG)	Semanas de embarazo calculadas desde la FUM o por biometría fetal
Preeclampsia	PA $\geq$ 140/90 mmHg + proteinuria $\geq$ 300 mg/24 h. Síndrome hipertensivo gestacional
Eclampsia	Preeclampsia con convulsiones. Emergencia obstétrica de máxima urgencia
RCIU	Restricción del Crecimiento Intrauterino. Peso fetal estimado <percentil 10 para la edad gestacional
Paridad (GPAC)	G=Gestas, P=Partos, A=Abortos, C=Cesáreas. Código de antecedentes obstétricos
CIE-10	Clasificación Internacional de Enfermedades, 10. ^a revisión. Estándar para codificación de diagnósticos

1.3 Actores del Sistema

Tabla 2

Actores del sistema y sus atribuciones

Actor	Permisos	Objetivos principales
Administrador General	CRUD total, configuración multi-sucursal, gestión de usuarios, reportes globales	Control operativo y financiero de la cadena de clínicas
Médico Especialista	Crear/editar historias clínicas, solicitar laboratorio, validar análisis de IA, prescribir	Diagnóstico y tratamiento gineco-obstétrico
Médico de Laboratorio	Ingresar resultados, subir imágenes DICOM, ver órdenes asignadas	Procesamiento de muestras y análisis de imágenes ecográficas
Enfermera/Paramédico	Registrar signos vitales, crear notas de enfermería, visualizar historia (sin editar diagnóstico)	Seguimiento y cuidado del paciente
Recepcionista	Registrar pacientes, agendar citas, facturación, reportes de sucursal	Operación administrativa diaria

1.4 Normativa Legal Aplicable en Bolivia

Tabla 3

Marco normativo y su impacto en el sistema

Normativa	Descripción	Impacto en el sistema
Ley 3131 (2005)	Ejercicio Profesional Médico en Bolivia	Todo diagnóstico debe ser firmado digitalmente por médico habilitado
Ley 164 (2011)	Telecomunicaciones, TIC y protección de datos	Cifrado obligatorio, consentimiento informado, prohibición de compartir datos sin autorización
DS 1793 (2013)	Reglamento Ley 164	Auditoría de acceso, retención mínima de datos médicos 10 años
RM 1328	Historia clínica como documento legal en Bolivia	Inmutabilidad del registro, firma del profesional, retención mínima garantizada
ISO/IEC 27001:2022	Seguridad de la Información	Gestión de seguridad, auditoría y políticas de acceso
IEC 62304:2006+A1	Software de Dispositivos Médicos	Documentación de requisitos, trazabilidad y gestión de riesgos del software
HL7 FHIR R4	Interoperabilidad en salud	Estructura de recursos clínicos para integración futura con otros sistemas
DICOM 3.0 (NEMA PS3)	Estándar de imágenes médicas	Almacenamiento y transmisión de ecografías

1.5 Riesgos del Dominio

Tabla 4

Riesgos críticos del dominio y estrategias de mitigación

Riesgo	Impacto	Estrategia de mitigación
Falso negativo CNN (patología no detectada)	CATASTRÓFICO — pérdida fetal o muerte materna	Umbral de confianza ≥ 0.92 , validación médica obligatoria antes de cualquier acción clínica
Falso positivo CNN (hallazgo inexistente)	Muy alto — procedimientos innecesarios, demanda legal	Mismo umbral, advertencia explícita al médico, validación humana siempre requerida
Pérdida de historia clínica	Muy alto — responsabilidad legal	Backups cada 4 horas, replicación, audit logs inmutables
Acceso no autorizado a datos	Alto — violación Ley 164	MFA, RBAC, AES-256, logs de acceso auditables
Error en cálculos clínicos	Alto — diagnóstico errado	Fórmulas validadas por especialistas, testing con casos reales

2. Arquitectura del Sistema

2.1 Justificación de la Arquitectura de Microservicios

Bass et al. (2022) definen la arquitectura de microservicios como la descomposición del sistema en servicios pequeños, independientemente desplegados, que se comunican mediante APIs bien definidas. Para el presente sistema, esta elección se justifica en tres razones principales: (a) el módulo de IA/ML requiere recursos GPU intensivos que deben escalar independientemente del módulo administrativo, (b) un fallo en el servicio de análisis ecográfico no debe propagar a los módulos clínicos ni interrumpir la atención de pacientes, y (c) la arquitectura monolítica Django no permite el aislamiento de fallos requerido para un sistema médico de criticidad máxima.

2.2 Componentes del Sistema

Tabla 5
Microservicios del sistema y sus responsabilidades

Servicio	Tecnología	Responsabilidad	Comunicación
API Gateway	Kong 3.x	Enrutamiento, autenticación JWT, rate limiting, SSL termination	Punto de entrada único para todos los clientes
Auth Service	Django + SimpleJWT	Registro, login, MFA, gestión de roles RBAC	REST síncrono, consultado por API Gateway
Clinical Core	Django REST Framework	Historias clínicas, consultas, diagnósticos, prescripciones, CPN	REST síncrono; eventos asíncronos a RabbitMQ
Laboratory Service	Django REST Framework	Órdenes de laboratorio, resultados, alertas de valores críticos	REST síncrono; publica eventos cuando resultado disponible
ML/AI Service	FastAPI + PyTorch 2	Inferencia CNN sobre imágenes DICOM, reportes de IA	Asíncrono: recibe tarea de Celery, publica resultado a RabbitMQ
DICOM Service	Orthanc + FastAPI	Almacenamiento DICOM, conversión a PNG para IA, visor OHIF	REST para subida; MinIO para almacenamiento
Admin Service	Django REST Framework	Sucursales, usuarios, facturación, reportes, configuración	REST síncrono
Notification Service	FastAPI + Redis	Notificaciones en tiempo real (WebSocket), alertas críticas	Suscribe a RabbitMQ, publica vía WebSocket
Frontend	React 18 + TypeScript	SPA multi-módulo: historia clínica, laboratorio, IA viewer, admin	Consume API Gateway; WebSocket para tiempo real

2.3 Decisiones Arquitectónicas (ADR)

ADR-001: FastAPI para el servicio de ML

FastAPI con Uvicorn es async-nativo y el framework Python con mayor rendimiento según TechEmpower Framework Benchmarks (2023). La latencia requerida para inferencia CNN es <2 segundos; Django introduce overhead de ORM y middleware incompatible con este requisito.

ADR-002: PostgreSQL como base de datos principal

Kleppmann (2017) destaca que la consistencia eventual de bases de datos NoSQL es inaceptable en sistemas donde los datos tienen valor legal. PostgreSQL 16 garantiza ACID compliance obligatorio para la integridad de historias clínicas. La extensión JSONB cubre los datos semiestructurados sin sacrificar transaccionalidad.

ADR-003: RabbitMQ para mensajería asíncrona

Apache Kafka fue evaluado y descartado por exceso de complejidad operacional para un equipo de un desarrollador. RabbitMQ con exchanges tipo topic cubre el volumen de ~250 eventos de ecografía diarios con menor overhead de administración.

ADR-004: MinIO para almacenamiento DICOM

La Ley 164 de Bolivia impone restricciones implícitas sobre el almacenamiento de datos sensibles fuera del país. MinIO, compatible con API S3, permite despliegue on-premise respetando esta restricción y facilita migración futura a nube si la regulación lo permite.

ADR-005: Orthanc como servidor PACS

Orthanc es el servidor DICOM open-source de mayor madurez en producción hospitalaria, con REST API nativa y plugin de visor OHIF integrable. Almacenar imágenes DICOM directamente en PostgreSQL como campos bytea es un antipatrón reconocido que degrada significativamente el rendimiento de la base de datos (Tanenbaum & Van Steen, 2016).

3. Metodología de Desarrollo

3.1 Scrum Híbrido con Compliance Gates

Dado el perfil del proyecto —equipo de un desarrollador, componentes de IA que requieren investigación exploratoria, y nivel de criticidad médica máximo— se adopta Scrum (Schwaber & Sutherland, 2020) con dos adaptaciones: Spikes obligatorios antes del Sprint 1 para validar viabilidad técnica del módulo CNN, y Compliance Gates al final de cada fase para verificar requisitos normativos (IEC 62304) antes de avanzar. Esta combinación, descrita por Pressman y Maxim (2020) como proceso ágil disciplinado, provee agilidad sin sacrificar la trazabilidad exigida en software médico.

3.2 Fases del Proyecto

Tabla 6

Fases del proyecto con entregables por fase

Fase	Duración	Entregables obligatorios
F0 — Spikes e infraestructura	2 semanas	Docker Compose completo. 4 spikes completados: CNN, DICOM, multi-tenant, Kong Gateway
F1 — Autenticación y pacientes	2 semanas	Auth con MFA funcional. CRUD de pacientes. Historia clínica base. API documentada con OpenAPI
F2 — Historia clínica completa	2 semanas	Consultas obstétricas, antecedentes, control prenatal, diagnósticos CIE-10, prescripciones
F3 — Laboratorio	1.5 semanas	Órdenes y resultados de laboratorio. Alertas de valores críticos. Integración con historia
F4 — DICOM e IA v1	3 semanas	Subida DICOM. CNN con ≥ 3 patologías detectadas. Reporte con Grad-CAM. Validación médica
F5 — Administración multi-sucursal	1.5 semanas	Gestión de clínicas y usuarios. Aislamiento de datos por sucursal. Facturación básica
F6 — Seguridad y compliance	1 semana	MFA verificado. Cifrado end-to-end. Audit logs. Checklist OWASP Top 10 completado
F7 — Validación clínica y despliegue	1 semana	UAT firmado por médico especialista. Despliegue en producción. Documentación completa

3.3 Artefactos de Ingeniería a Producir

- **SRS — Especificación de Requisitos del Software (IEEE 830-1998)**
- **SAD — Software Architecture Document** (Bass et al., 2022)
- **ADRs — Architecture Decision Records** (mínimo 5)
- **Diagramas UML:** Casos de Uso, Clase, Secuencia, Componentes, Despliegue

- Backlog de producto priorizado con criterios de aceptación por historia
- Pipeline ML documentado: dataset, preprocesamiento, métricas, validación clínica
- Documentación de API en formato OpenAPI 3.1
- Informe de evaluación de calidad ISO/IEC 25010
- Manual de usuario por rol y manual de despliegue

4. Stack Tecnológico Completo

Tabla 7

Stack tecnológico recomendado por capa del sistema

Capa	Tecnología	Versión	Justificación	Alternativa
Frontend	React + TypeScript + Vite	React 18, TS 5	Ecosistema maduro para SPAs médicas; TypeScript previene errores de tipo en datos clínicos	Vue 3 + Nuxt
UI Components	Ant Design (antd)	5.x	Componentes enterprise para tablas complejas y formularios clínicos sin diseño desde cero	Material-UI
State Management	Zustand + React Query	Zustand 4, RQ 5	React Query para server state con caché; Zustand para UI state. Más simple que Redux	Redux Toolkit
DICOM Viewer	OHIF Viewer	3.x	Visor DICOM open-source estándar clínico con integración nativa a Orthanc	Cornerstone.js
Backend principal	Django + DRF	Django 5, DRF 3.15	ORM maduro, autenticación robusta, serializers para datos clínicos médicos	FastAPI solo
ML Service	FastAPI + PyTorch	FastAPI 0.110, PT 2.2	FastAPI async para inferencia <2 s; PyTorch con ecosistema MONAI médico	TensorFlow
DICOM Server	Orthanc	1.12	Servidor DICOM open-source hospitalario con REST API y plugin OHIF	DCM4CHEE
Base de datos	PostgreSQL	16.x	ACID compliance obligatorio para datos médicos. JSONB para semiestructurados	MySQL 8
Caché	Redis	7.x	Caché de sesiones, rate limiting, Pub/Sub para notificaciones en tiempo real	Memcached
Mensajería	RabbitMQ	3.13	Desacoplamiento entre servicios clínicos y ML con menor complejidad que Kafka	Apache Kafka
API Gateway	Kong	3.x	Rate limiting, JWT validation, SSL termination, plugins de salud open-source	Nginx + middleware
Almacenamiento	MinIO	2024	Compatible API S3. On-premise para cumplir Ley 164 Bolivia	AWS S3
IA médica	MONAI	1.3	Framework PyTorch especializado en IA médica con transforms DICOM y modelos pre-entrenados	PyTorch puro

Capa	Tecnología	Versión	Justificación	Alternativa
Infraestructura	Docker + K3s	Docker 25, K3s 1.29	Docker Compose para desarrollo; K3s (Kubernetes ligero) para producción multi-sucursal	Docker Swarm
CI/CD	GitHub Actions	—	Pipelines de test, lint, build y deploy automatizados integrados con repositorio	GitLab CI
Monitoreo	Prometheus + Grafana + Sentry	Prom 2.50, Grafana 10	Métricas de sistema, dashboards y errores de aplicación centralizados	Datadog
Secretos	HashiCorp Vault	1.16	Gestión centralizada de credenciales. Nunca en código ni en archivos .env en producción	Doppler

5. Modelo de Datos

5.1 Entidades Principales

Tabla 8

Entidades del modelo de datos y sus relaciones

Entidad	Campos esenciales	Cardinalidad
Clinica	id (UUID), nombre, licencia_sanitaria, ciudad, activa (bool)	1 Clínica → N Usuarios, N Pacientes
Usuario	id, clinica_id (FK), nombres, apellidos, email, password_hash, rol (ENUM), registro_profesional, mfa_secret	N Usuarios → 1 Clínica
Paciente	id, clinica_id (FK), nombres, apellidos, fecha_nacimiento, ci (cifrado), grupo_sanguineo, alergias (JSONB)	1 Paciente → 1 HistoriaClinica, N Consultas
HistoriaClinica	id, paciente_id (FK), antecedentes_personales (JSONB), antecedentes_obstetricos (JSONB: G,P,A,C,FUM)	1 Historia → N ConsultasObstetricas
ConsultaObstetrica	id, historia_id (FK), medico_id (FK), examen_fisico (JSONB: PA, peso, AU, FCF), diagnostico_cie10 (array), firmado_at	N Consultas → N OrdenesLab, N Ecografías
OrdenLaboratorio	id, consulta_id (FK), examenes_solicitados (JSONB), urgente (bool), estado (ENUM)	1 Orden → N ResultadosLaboratorio
ResultadoLaboratorio	id, orden_id (FK), valor_resultado, unidad, estado_alerta (ENUM: NORMAL ALTO BAJO CRITICO)	N Resultados → 1 Orden
Ecografia	id, consulta_id (FK), tipo (ENUM), dicom_study_id (ref Orthanc), estado_analisis_ia (ENUM)	1 Ecografía → 1 AnalisisIA
AnalisisIA	id, ecografia_id (FK), modelo_version, hallazgos (JSONB), score_global (float), riesgo_preeclampsia (float), validado_por_medico_id (FK), validacion_estado (ENUM)	1 AnalisisIA → 1 Ecografia
AuditLog	id, usuario_id (FK), accion (ENUM), entidad_id, datos_anteriores (JSONB), datos_nuevos (JSONB), ip_address, timestamp (immutable)	Tabla append-only, sin UPDATE ni DELETE

5.2 Estándares de Datos Aplicados

- **CIE-10 (OMS): Clasificación Internacional de Enfermedades para codificación de diagnósticos en campo diagnostico_cie10.**

- HL7 FHIR R4: Las entidades del modelo están diseñadas para ser mapeables a recursos FHIR Patient, Observation y DiagnosticReport para interoperabilidad futura.
- DICOM 3.0 (NEMA PS3): Almacenamiento y transmisión de imágenes ecográficas mediante servidor Orthanc.
- SNOMED-CT: Para terminología de hallazgos clínicos en el campo hallazgos (JSONB) del AnalisisIA.

5.3 Política de Retención y Backup

- **Retención de historias clínicas: mínimo 10 años conforme a DS 1793 y RM 1328 de Bolivia.**
- Backups automáticos de PostgreSQL cada 4 horas (pg_dump) con retención de 90 días.
- Backup completo semanal a almacenamiento externo cifrado con GPG.
- Imágenes DICOM en MinIO con backup incremental diario y retención indefinida.
- Tabla AuditLog: append-only, retención mínima 5 años, usuario de aplicación sin permisos UPDATE/DELETE.

6. Componente de Inteligencia Artificial

6.1 Advertencia de Uso Clínico

El módulo de IA es soporte diagnóstico. No reemplaza al médico especialista. Todo análisis generado debe ser revisado y validado por el médico responsable antes de influir en cualquier decisión clínica. Esta condición es requisito legal bajo la Ley 3131 de Bolivia y requisito ético conforme a los principios de beneficencia y no maleficencia de la bioética médica.

6.2 Arquitectura del Modelo CNN

Se adopta EfficientNet-B4 con transfer learning desde ImageNet, adaptado al dominio ecográfico mediante fine-tuning sobre dataset obstétrico. Tan y Le (2019) demostraron que EfficientNet supera a ResNet y VGG en la relación accuracy/parámetros. Tajbakhsh et al. (2016) confirmaron en IEEE Transactions on Medical Imaging que el transfer learning desde ImageNet es efectivo para imágenes médicas incluso con datasets limitados. Para biometría fetal se añade una rama de regresión; para detección de patologías, una cabeza de clasificación multi-label (una salida por patología, no mutuamente excluyentes). La biblioteca MONAI (Medical Open Network for AI) provee transforms DICOM, métricas clínicas y modelos pre-entrenados en dominio médico.

6.3 Condiciones Clínicas a Detectar

Tabla 9

Condiciones clínicas detectables por el módulo de IA

Categoría	Condición clínica	Tarea ML
Anomalías fetales estructurales	Defectos del tubo neural (anencefalia, espina bífida), malformaciones cardíacas, labio leporino	Clasificación binaria por patología
Crecimiento fetal	RCIU, macrosomía, biometría (BPD, HC, AC, FL, peso estimado)	Regresión + clasificación de percentil
Patología placentaria	Placenta previa, desprendimiento prematuro, calcificaciones	Clasificación + segmentación
Líquido amniótico	Oligohidramnios, polihidramnios (cálculo del ILA)	Regresión numérica del índice
Riesgo materno	Preeclampsia, parto prematuro (scores de probabilidad)	Score de probabilidad 0–1
Anomalías ginecológicas	Miomas, quistes ováricos, patología cervical	Clasificación + localización

6.4 Pipeline Completo de ML

1. Adquisición de datos: imágenes DICOM de ecografías obstétricas. Mínimo 5,000 imágenes etiquetadas para entrenamiento inicial viable. Fuente base: dataset público FETAL_PLANES_DB (Thomas et al., 2021). Ampliación con imágenes propias anonimizadas bajo consentimiento informado.
2. Anonimización: eliminación de metadatos DICOM con información personal mediante pydicom + dicomanon antes de cualquier uso para entrenamiento.
3. Preprocesamiento: normalización de intensidades, resize a 384×384, conversión DICOM→PNG, data augmentation (rotación $\pm 15^\circ$, flip horizontal, variación de brillo y contraste).
4. Etiquetado: realizado exclusivamente por médico especialista (ginecólogo-obstetra o radiólogo). Herramienta: Label Studio con interfaz DICOM. Formato: COCO JSON para detección, CSV para clasificación multi-label.
5. Entrenamiento: EfficientNet-B4 pre-entrenado, fine-tuning en dos fases. Optimizer: AdamW con scheduler coseno. Loss: BCE para multi-label, MSE para regresión de biometría.
6. Validación técnica: split 70/15/15. Métricas: AUC-ROC, F1-score, Sensibilidad, Especificidad, Kappa de Cohen, MAE para biometría.
7. Validación clínica: el médico especialista revisa muestra de 200 casos del test set. El modelo entra a producción solo con aceptación documentada del especialista.
8. Deploy: modelo empaquetado en FastAPI. Inferencia con ONNX para optimización. Logging de cada inferencia con hash del input, output, tiempo y versión del modelo.
9. Monitoreo: data drift detection mensual con Evidently AI. Alerta si PSI (Population Stability Index) > 0.15 .
10. Reentrenamiento: mensual con datos etiquetados por médico. El modelo nuevo no reemplaza al anterior hasta pasar validación técnica y clínica. Versionado con MLflow.

6.5 Métricas de Aceptación del Modelo

Tabla 10

Umbral de métricas para aceptación del modelo en producción

Métrica	Umbral mínimo	Umbral óptimo
AUC-ROC (anomalías)	≥ 0.90	≥ 0.95
Sensibilidad / Recall	≥ 0.92 — CRÍTICO	≥ 0.96
Especificidad	≥ 0.85	≥ 0.92
F1-Score promedio multi-label	≥ 0.85	≥ 0.90
Kappa de Cohen	≥ 0.75 (acuerdo sustancial)	≥ 0.85
MAE biometría fetal	≤ 3.0 mm	≤ 1.5 mm

Métrica	Umbral mínimo	Umbral óptimo
Tiempo de inferencia	< 3 segundos	< 1.5 segundos
Acuerdo con médico (validación clínica)	$\geq 85\%$	$\geq 92\%$

6.6 Explicabilidad XAI

En sistemas médicos, la IA no puede ser una caja negra. El médico debe comprender el fundamento de cada decisión. Se implementan: (a) Grad-CAM (Selvaraju et al., 2017): genera mapa de calor sobre la imagen ecográfica resaltando las regiones que activaron la detección, visualizado en el OHIF Viewer sobre la imagen original; (b) SHAP (Lundberg & Lee, 2017): para los scores de riesgo materno, muestra qué variables clínicas (semanas de gestación, presión arterial, IMC, antecedentes) contribuyeron más al score; (c) barra de confianza por hallazgo con código de color: verde $\geq 85\%$, amarillo 70–85 %, rojo $< 70\%$.

7. Seguridad y Privacidad

7.1 Modelo de Amenazas STRIDE

Tabla 11

Amenazas STRIDE aplicadas al sistema y controles implementados

Amenaza	Descripción en el sistema	Control implementado
Spoofing	Acceso con credenciales robadas de médico	MFA obligatorio (TOTP), bloqueo tras 5 intentos fallidos, alerta por IP nueva
Tampering	Modificación de historia clínica o resultado de IA	Audit logs inmutables, firma digital de diagnósticos, hash de registros críticos
Repudiation	Médico niega diagnóstico emitido	Firma digital con timestamp en UTC, audit log con IP y user-agent
Information Disclosure	Exposición de datos de pacientes	AES-256 en reposo, TLS 1.3 en tránsito, RBAC estricto, cifrado de CI y datos personales
Denial of Service	Saturación del servidor de IA o base de datos	Rate limiting en Kong, Circuit Breaker, colas RabbitMQ absorben picos
Elevation of Privilege	Enfermera accede al módulo de administración	RBAC en API Gateway + Django Guardian, validación por endpoint, mínimo privilegio

7.2 Controles de Autenticación y Autorización

- **JWT con expiración de 15 minutos más Refresh Token de 7 días en cookie HTTPOnly segura.**
- MFA obligatorio (TOTP compatible con Google Authenticator) para roles MEDICO, LABORATORIO y ADMIN.
- RBAC: cinco roles con permisos granulares por endpoint y por objeto mediante django-guardian.
- Bloqueo de cuenta tras cinco intentos fallidos con notificación al administrador.
- Sesión ligada a IP y User-Agent; alerta automática si cambian durante sesión activa.

7.3 Cifrado y Protección de Datos

- **En reposo: AES-256 para campos sensibles (CI, teléfono, dirección) con django-cryptography; cifrado transparente de PostgreSQL.**
- En tránsito: TLS 1.3 obligatorio en todos los endpoints; sin soporte a TLS 1.1/1.2.
- Imágenes DICOM en MinIO cifradas con SSE (Server-Side Encryption) AES-256.
- Backups cifrados con GPG antes de almacenamiento externo.

7.4 OWASP Top 10 — Controles

Tabla 12

Controles de seguridad frente a OWASP Top 10 (2021)

OWASP Top 10 (2021)	Control implementado en Fetal Medical Bolivia
A01 Broken Access Control	RBAC en API Gateway + Django Guardian. Tests automatizados de permisos por rol.
A02 Cryptographic Failures	AES-256 + TLS 1.3. Sin MD5/SHA1. Gestión de secretos con HashiCorp Vault.
A03 Injection	ORM Django sin SQL raw. Serializers DRF con validación estricta. Parameterized queries.
A04 Insecure Design	Threat modeling STRIDE desde el diseño. Principio de mínimo privilegio en toda la arquitectura.
A05 Security Misconfiguration	Django DEBUG=False en producción. Variables de entorno vía Vault. Docker hardened.
A06 Vulnerable Components	Dependabot alerts activo. pip-audit + npm audit en pipeline CI/CD.
A07 Auth Failures	MFA obligatorio. Bloqueo por intentos fallidos. JWT de 15 min.
A08 Integrity Failures	Checksums de imágenes Docker. Firma de commits. Dependencias con hash en lockfiles.
A09 Logging Failures	ELK Stack centralizado. Sentry para errores de aplicación. Audit logs inmutables.
A10 SSRF	Whitelist de URLs permitidas. Bloqueo de rangos IP internos en llamadas a servicios externos.

8. Aspectos Críticos Frecuentemente Omitidos

8.1 Consentimiento Informado Digital

Antes de registrar cualquier paciente, el sistema genera un documento de consentimiento informado que explica: qué datos se recopilan, para qué se usan, cómo se protegen, que el análisis de IA es soporte diagnóstico y no sustituto médico, y que las imágenes ecográficas pueden usarse anonimizadas para mejorar el modelo. El consentimiento se firma con firma electrónica simple (acción afirmativa + timestamp + IP) y se almacena en la historia clínica. Sin consentimiento firmado, el sistema no permite crear la historia clínica.

8.2 Responsabilidad Legal por Resultados

Cada análisis de IA incluye la leyenda: «Análisis generado por sistema de apoyo diagnóstico versión X.X.X. El Dr./Dra. [nombre] con matrícula [número] ha revisado y validado el diagnóstico final, asumiendo la responsabilidad profesional del mismo.» Esto establece trazabilidad legal clara: la responsabilidad del diagnóstico final recae siempre en el médico que lo valida y firma, no en el sistema de IA.

8.3 Plan de Recuperación ante Desastres

Tabla 13

RTO y RPO por escenario de falla

Escenario	RTO	RPO	Procedimiento
Caída de un microservicio	< 2 min	0	K3s reinicia contenedor automáticamente. Health checks cada 30 segundos.
Corrupción de base de datos	< 30 min	< 4 h	Restaurar desde backup más reciente. Validar integridad con checksums.
Pérdida total del servidor	< 4 h	< 4 h	Restaurar VM desde snapshot. Restaurar BD y DICOMs desde backup externo.
Ransomware o ciberataque	< 24 h	< 24 h	Activar servidor de contingencia aislado. Restaurar desde backup offline. Notificar autoridades.
Falla de disco MinIO	< 2 h	< 24 h	MinIO con erasure coding. Backup incremental diario a disco externo cifrado.

8.4 Versionado de APIs

Todas las APIs se versionan con prefijo de URL (/api/v1/, /api/v2/). La versión anterior se mantiene operativa mínimo seis meses tras publicar una nueva versión. Los

cambios breaking se anuncian en el changelog con mínimo 30 días de anticipación. Kong gestiona el routing entre versiones.

8.5 Onboarding Técnico en Menos de 30 Minutos

11. `git clone https://github.com/[org]/fetal-medical-bolivia`
12. `cp .env.example .env` — editar variables de entorno
13. `docker compose up -d` — levanta todos los servicios
14. `docker compose exec backend python manage.py migrate`
15. `docker compose exec backend python manage.py loaddata initial_data.json`
16. `docker compose exec ml-service python scripts/download_model.py`
17. Abrir `http://localhost:3000` en el navegador

9. Plan de Construcción

9.1 Spikes de Investigación Obligatorios

Tabla 14

Spikes de investigación previos al Sprint 1

Spike	Objetivo	Duración	Criterio de Done
CNN Médico	Validar que EfficientNet-B4 con MONAI puede cargar DICOM e inferir	3 días	Script funcional sobre 10 imágenes DICOM con output de clasificación
DICOM-Orthanc	Validar subida DICOM a Orthanc y recuperación vía REST	2 días	DICOM subido, recuperado y visualizado en OHIF Viewer local
Multi-tenant Django	Validar aislamiento de datos por clínica en PostgreSQL	2 días	2 clínicas en BD; usuario de clínica A no ve datos de clínica B
Kong Gateway	Validar JWT validation y routing a microservicios	1 día	Request con JWT válido llega a backend; sin JWT retorna 401

9.2 Definition of Done por Tipo de Historia

Historia clínica funcional

- **Código implementado con self-review y checklist de calidad**
- Tests unitarios con cobertura ≥ 80 % de la lógica de negocio
- Test de integración con la base de datos aprobado
- Validado manualmente en entorno de staging
- Documentación de API actualizada en OpenAPI 3.1
- Sin vulnerabilidades críticas en bandit (Python security linter)

Historia de ML/IA

- **Métricas técnicas cumplen umbrales de la Tabla 10**
- Validación clínica completada y documentada por médico especialista
- Explicabilidad Grad-CAM visible en el frontend
- Modo degradado probado y documentado
- Modelo versionado en MLflow

Historia de seguridad y normativa

- **Control OWASP correspondiente verificado**
- Audit log genera entrada correcta para la acción
- Test de acceso no autorizado (rol incorrecto $\rightarrow$ HTTP 403)

- Documentado en SAD y en checklist de compliance IEC 62304

10. Tabla de Validación Final del Sistema

Tabla 15

Criterios de completitud del sistema por dimensión

Dimensión	Criterio de completitud	Cómo verificarlo	Referencia
Funcionalidad clínica	Historia clínica, laboratorio y ecografías funcionando en producción con 250 pacientes/día	UAT con médico especialista completado y firmado	IEEE 830; Sommerville, 2016
IA — Precisión	AUC-ROC ≥ 0.90 , Sensibilidad ≥ 0.92 , validación clínica $\geq 85\%$	Reporte de métricas MLflow y documento de validación médica	Tajbakhsh et al., 2016 IEEE TMI
IA — Explicabilidad	Grad-CAM visible en visor OHIF. SHAP en scores de riesgo	Demo con médico que interpreta el mapa de calor	Selvaraju et al., 2017
IA — Modo degradado	Sistema funciona sin módulo IA; cola procesa backlog al restaurarse	Apagar ML Service → crear consulta → estado PENDIENTE → restaurar → analiza cola	Bass et al., 2022
Autenticación	MFA activo. JWT 15 min. Bloqueo por intentos fallidos	Login sin MFA → bloqueado. Token expirado → 401. 6 intentos → cuenta bloqueada	OWASP ASVS v4.0
Cifrado	AES-256 en reposo. TLS 1.3 en tránsito. Campos sensibles cifrados	CI del paciente cifrado en BD. SSL Labs Grade A en producción	ISO 27001:2022
Audit Log	Todas las acciones críticas en tabla inmutable con datos anteriores y nuevos	Modificar historia → verificar AuditLog. DELETE en AuditLog → error de permisos	Ley 164, RM 1328
Multi-tenant	Clínica A no puede ver datos de clínica B bajo ninguna circunstancia	Usuario de clínica A accede a paciente de clínica B vía API → 403	OWASP A01
DICOM	Imágenes en formato DICOM válido. Visualizables en OHIF Viewer	Subir DICOM → verificar en Orthanc → abrir en OHIF → imagen visible	DICOM 3.0 NEMA PS3
Consentimiento	Todo paciente tiene consentimiento firmado antes de crear historia	Intentar crear historia sin consentimiento → sistema lo bloquea	Ley 164 Bolivia
Rendimiento	Inferencia IA <3 s. Carga de historia <2 s. 250	Load test con k6 a 250 usuarios. P95 de tiempos de respuesta medido	ISO/IEC 25010:2011

Dimensión	Criterio de completitud	Cómo verificarlo	Referencia
	usuarios simultáneos sin degradación		
Calidad de código	Cobertura tests ≥ 75 %. Sin vulnerabilidades críticas. Lint aprobado	pytest --cov. bandit scan. flake8 / eslint sin errores críticos	Pressman & Maxim, 2020

Referencias

Bass, L., Clements, P., & Kazman, R. (2022). *Software architecture in practice* (4th ed.). Addison-Wesley.

Kleppmann, M. (2017). *Designing data-intensive applications: The big ideas behind reliable, scalable, and maintainable systems*. O'Reilly Media.

Lundberg, S. M., & Lee, S. I. (2017). A unified approach to interpreting model predictions. *Advances in Neural Information Processing Systems*, 30, 4765–4774.

Open Web Application Security Project (OWASP). (2021). OWASP Top 10: 2021. <https://owasp.org/Top10/>

Pressman, R. S., & Maxim, B. R. (2020). *Software engineering: A practitioner's approach* (9th ed.). McGraw-Hill.

Schwaber, K., & Sutherland, J. (2020). *The Scrum guide*. Scrum.org. <https://scrumguides.org>

Selvaraju, R. R., Cogswell, M., Das, A., Vedantam, R., Parikh, D., & Batra, D. (2017). Grad-CAM: Visual explanations from deep networks via gradient-based localization. *Proceedings of the IEEE International Conference on Computer Vision (ICCV)*, 618–626.

Shostack, A. (2014). *Threat modeling: Designing for security*. Wiley.

Sommerville, I. (2016). *Software engineering* (10th ed.). Pearson.

Tajbakhsh, N., Shin, J. Y., Gurudu, S. R., Hurst, R. T., Kendall, C. B., Gotway, M. B., & Liang, J. (2016). Convolutional neural networks for medical image analysis: Full training or fine tuning? *IEEE Transactions on Medical Imaging*, 35(5), 1299–1312. <https://doi.org/10.1109/TMI.2016.2535302>

Tan, M., & Le, Q. V. (2019). EfficientNet: Rethinking model scaling for convolutional neural networks. *Proceedings of the 36th International Conference on Machine Learning (ICML)*. <https://arxiv.org/abs/1905.11946>

Tanenbaum, A. S., & Van Steen, M. (2016). Distributed systems: Principles and paradigms (3rd ed.). Pearson.

Thomas, M., Marques, J., & Papageorghiou, A. T. (2021). Automatic measurement of fetal head biometry from ultrasound. Scientific Data, 8, 96. <https://doi.org/10.1038/s41597-021-00874-4>

Normativa

Asamblea Legislativa Plurinacional de Bolivia. (2011). Ley N.º 164: Ley General de Telecomunicaciones, Tecnologías de Información y Comunicación. Estado Plurinacional de Bolivia.

Congreso Nacional de Bolivia. (2005). Ley N.º 3131: Ley del Ejercicio Profesional Médico. República de Bolivia.

Ministerio de Salud de Bolivia. (s.f.). Resolución Ministerial N.º 1328: Historia clínica como documento legal. Ministerio de Salud y Deportes.

Presidencia del Estado Plurinacional de Bolivia. (2013). Decreto Supremo N.º 1793: Reglamento de la Ley General de Telecomunicaciones, TIC.